

Definition

Threat exposure management encompasses processes and technologies that allow enterprises to continually and consistently assess the visibility and validate the accessibility and exploitability of their digital assets. It must be governed by an effective continuous threat exposure management (CTEM) program.

Why This Is Important

The diversity of modern infrastructure and reevaluation of what threat exposure is affect organizations' ability to accurately assess cyber risks. Security teams often struggle to identify modern exposures, leaving security gaps in systems such as SaaS and cyber-physical systems (CPS) security. Threat exposure management addresses these challenges by enabling identification, prioritization and validation of issues across diverse attack surfaces and ensuring comprehensive visibility and mitigation.

Business Impact

Threat exposure management governs and prioritizes risk reduction for the modern enterprise. It requires assessment of all business-related systems, applications and subscriptions, broadening risk understanding for today's digital landscape. CTEM programs factor in business importance, likelihood of attack, visibility of vulnerability and validation of the existence of an attack path, enabling businesses to mobilize responses to genuine, impactful risks.

Drivers

- Organizations' vulnerability management programs often lack alignment with business criticality. Organizations focus on volume rather than scoping a target set based on their priorities, leaving them with too much to do regarding their exposure and little guidance on which action to prioritize. Threat exposure management provides business alignment through the scoping process and helps reduce volumes of irrelevant or non-business-critical issues.
- A programmatic and repeatable approach to answer the question "How exposed are we?" is necessary for organizations. Threat exposure management aims to allow reprioritization of treatments as environments shift in a rapidly changing and expanding IT landscape.
- Organizations commonly silo exposure activities such as penetration testing, threat intelligence management and vulnerability scanning. Siloed views provide little or no awareness of the complete picture of cyber risk.

- Modern IT infrastructure, including subscriptions, SaaS applications and cloud environments, has introduced a much wider, more varied set of potential exposures, making organizations susceptible. Current approaches focus too much on traditional IT and vulnerability, when a large percentage of the exposure problem is focused elsewhere.
- Vendor offerings to identify threat exposures are evolving and consolidating into exposure assessment platforms (EAP), which offer greater visibility. This means that end users will have access to new information about potential threats without having to purchase new subscriptions.

Obstacles

- The increased scope of CTEM programs over traditional VM introduces many new complexities often not previously considered or budgeted for.
- While evaluating new exposures is necessary, effective response and the ability to mobilize a gradient of countermeasures, such as threat monitoring and control configuration, is lacking. Patching is the de facto response to vulnerability discovery.
- Processes to manage end-to-end awareness (from visibility of attack vectors to response to breaches) are virtually nonexistent in most organizations, which often simply scan their networks for compliance reasons. Regulations rarely factor in the exploitability of exposures.
- Assessing the complexity of attacks requires new skill sets. Market areas, such as adversarial exposure validation (AEV), make it simple to test the out-of-the-box scenarios using simulation tools. But users need new skills to be effective at using these capabilities and customizing scenarios.

User Recommendations

- Create agreements on tackling exposure with various organizational stakeholders, as success depends on it. Automated remediation from tools is unlikely to have a significant impact.
- Communicate the risks to the board. Senior executives must be aware of existing risks, and allocate resources to prepare against potential threats.
- Implement wider, more multiplatform programs, such as CTEM, to manage exposure. Include scoping and directional exposure awareness that deals with business-critical issues, not just “fire and forget” approaches.

- Prepare response and reaction plans. Monitoring for threat exposure issues is critical to limiting the potential impact of attacks. Validating that those exposures genuinely exist and security controls are functioning as expected is useful. However, it is essential that organizations also prepare reaction plans for the issues they may find to ensure resolution paths are effective.
- Include, in your CTEM program, assets that your organization doesn't directly own, such as social media accounts, SaaS and data held by supply chain partners.